

CLOUD SECURITY EVIDENCE REPORT

PACU PRIVILEGE ESCALATION SCAN

Project	Enterprise Security Assessment Lab
Module	04 - Cloud Security
Evidence File	pacu-privesc-scan-results.png
Report File	02-pacu-privilege-escalation-scan-evidence-report.pdf
Result Type	IAM privilege escalation analysis
Environment	AWS CloudGoat / AWS CLI / Pacu / ScoutSuite / Local Kali Lab
Publication Status	GitHub-ready portfolio report with sensitive values redacted

This document is an evidence-specific professional report. It explains one screenshot from the Cloud Security module, maps it to the testing methodology, interprets the tool output, and documents real-world risk, remediation and redaction requirements.

1. Embedded Evidence Screenshot

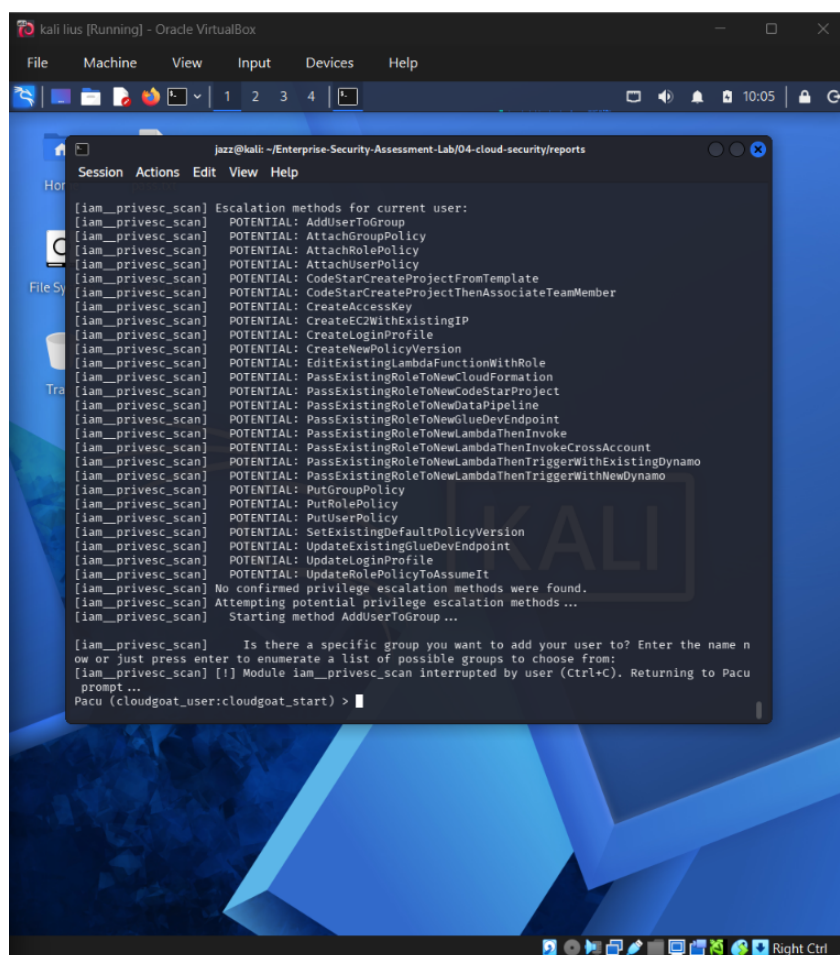


Figure 1 - Redacted evidence screenshot: pacu-privesc-scan-results.png

What this screenshot proves

The screenshot shows Pacu listing possible escalation methods such as policy attachment, user and role policy modification, PassRole-based paths, lambda-related escalation checks and other IAM abuse techniques. The scan then attempts a selected method and returns to the Pacu prompt.

2. Evidence Context

Testing Phase	Automated Cloud Privilege Escalation Review
Tool / Component	Pacu - iam__privesc_scan
Objective	Use Pacu to identify potential privilege escalation techniques available to the current IAM principal in the AWS lab.

Result Type	IAM privilege escalation analysis
Evidence Source	pacu-privesc-scan-results.png

3. Command / Workflow Used

The following sanitized workflow represents the command pattern or console path used for this evidence. Live identifiers, account values, tokens and credentials are intentionally replaced with placeholders.

```
pacu
set_keys
run iam__enum_permissions
run iam__privesc_scan
```

4. Sanitized Output Interpretation

The screenshot shows Pacu listing possible escalation methods such as policy attachment, user and role policy modification, PassRole-based paths, lambda-related escalation checks and other IAM abuse techniques. The scan then attempts a selected method and returns to the Pacu prompt.

The goal of this evidence is not simply to show that a tool was executed. It demonstrates that the tool output was reviewed and interpreted as part of a controlled cloud security assessment. In a professional assessment, raw tool output must always be converted into a clear technical explanation, business risk statement and remediation plan.

5. Security Impact and Risk Analysis

A single IAM permission often looks harmless alone, but privilege escalation frequently appears through permission combinations. Pacu helps reveal risky combinations that may let an attacker move from a limited identity to a more privileged one.

In a real cloud environment, the practical risk depends on the permissions of the identity, exposed services, network context, logging coverage and business sensitivity of the affected resources. This report treats the evidence as a lab finding but explains the likely real-world impact if the same condition existed in production.

MITRE / Control Mapping	T1098.003 - Additional Cloud Roles / T1078.004 - Cloud Accounts
Impact Area	Identity security, cloud configuration, exposure management and operational governance

Portfolio Value	Shows tool execution, interpretation, redaction discipline and professional reporting maturity
-----------------	--

6. Recommended Remediation

- Continuously review IAM permissions for known escalation patterns.
- Restrict policy write permissions to tightly controlled admin roles.
- Limit PassRole to specific roles and services.
- Use service control policies in larger AWS organizations.
- Log and alert on IAM policy changes, role assumption and unusual service activity.

7. GitHub Redaction and Publication Guidance

Any Pacu session data, imported access keys and role ARNs should be treated as sensitive. Only sanitized screenshots should be uploaded.

Before committing any cloud evidence to GitHub, review the screenshot for AWS account IDs, ARNs, IAM usernames, bucket names, EC2 instance IDs, access keys, secret keys, session tokens, Azure subscription identifiers, public IP addresses, billing details and local private paths. If any of those values are present, redact or blur them before upload.

Recommended GitHub folder	04-cloud-security/reports/evidence/
Report link format	./reports/evidence/02-pacu-privilege-escalation-scan-evidence-report.pdf
Evidence screenshot folder	04-cloud-security/screenshots/